

Respuesta ante Phishing

- NIST SP 800-61
- MITRE ATT&CK
- SANS
- ISO/IEC 27035

PREPARACIÓN · CONTINUO

SEG con SPF/DKIM/DMARC activo y sandboxing de adjuntos · simulacros de phishing periódicos · contacto de urgencia con Finanzas/Tesorería documentado para escalado BEC.

FASE 1 **Detección y Análisis**

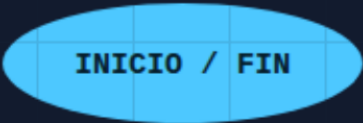
FASE 2 **Contención**

FASE 3 **Erradicación**

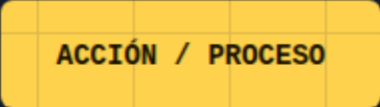
FASE 4 **Recuperación**

FASE 5 **Lecciones Aprendidas**

NOTACIÓN DEL DIAGRAMA



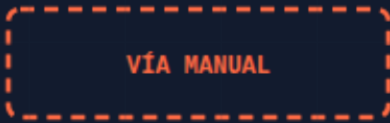
Círculo celeste
Inicio y fin del flujo



Rectángulo amarillo
Paso operativo



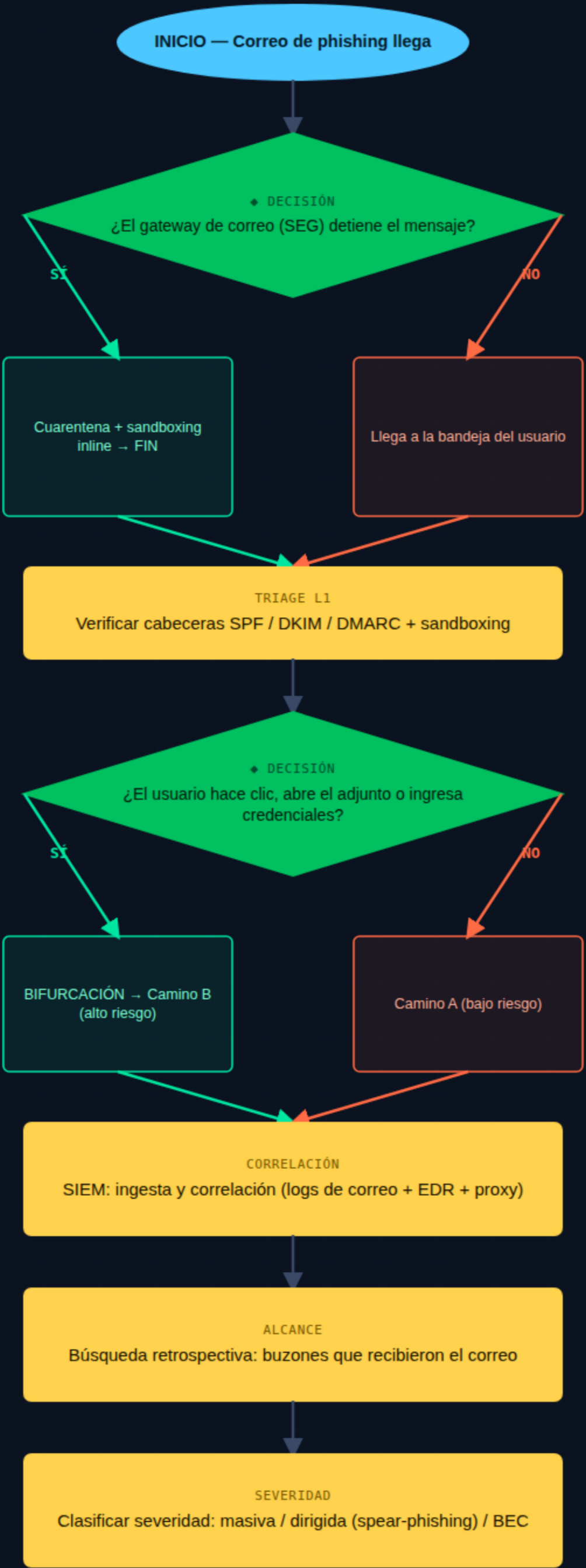
Rombo verde
Punto de decisión Sí / No



Recuadro punteado naranja
Contingencia manual

Respuesta ante Phishing

● FASE 1 – Detección y Análisis

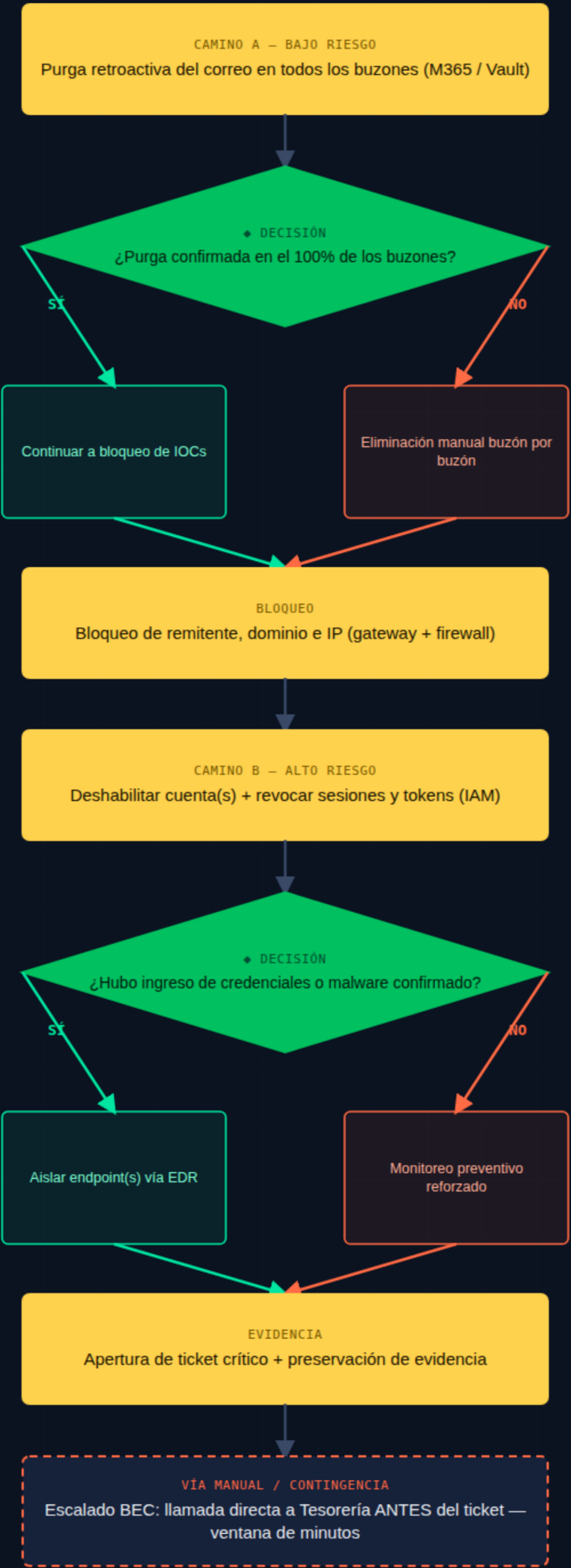


HERRAMIENTAS — DETECCIÓN Y ANÁLISIS

- ▶ Proofpoint TAP
- ▶ Mimecast
- ▶ Microsoft Defender for Office 365
- ▶ Cofense Triage
- ▶ Wazuh + Sysmon

Respuesta ante Phishing

● FASE 2 – Contención

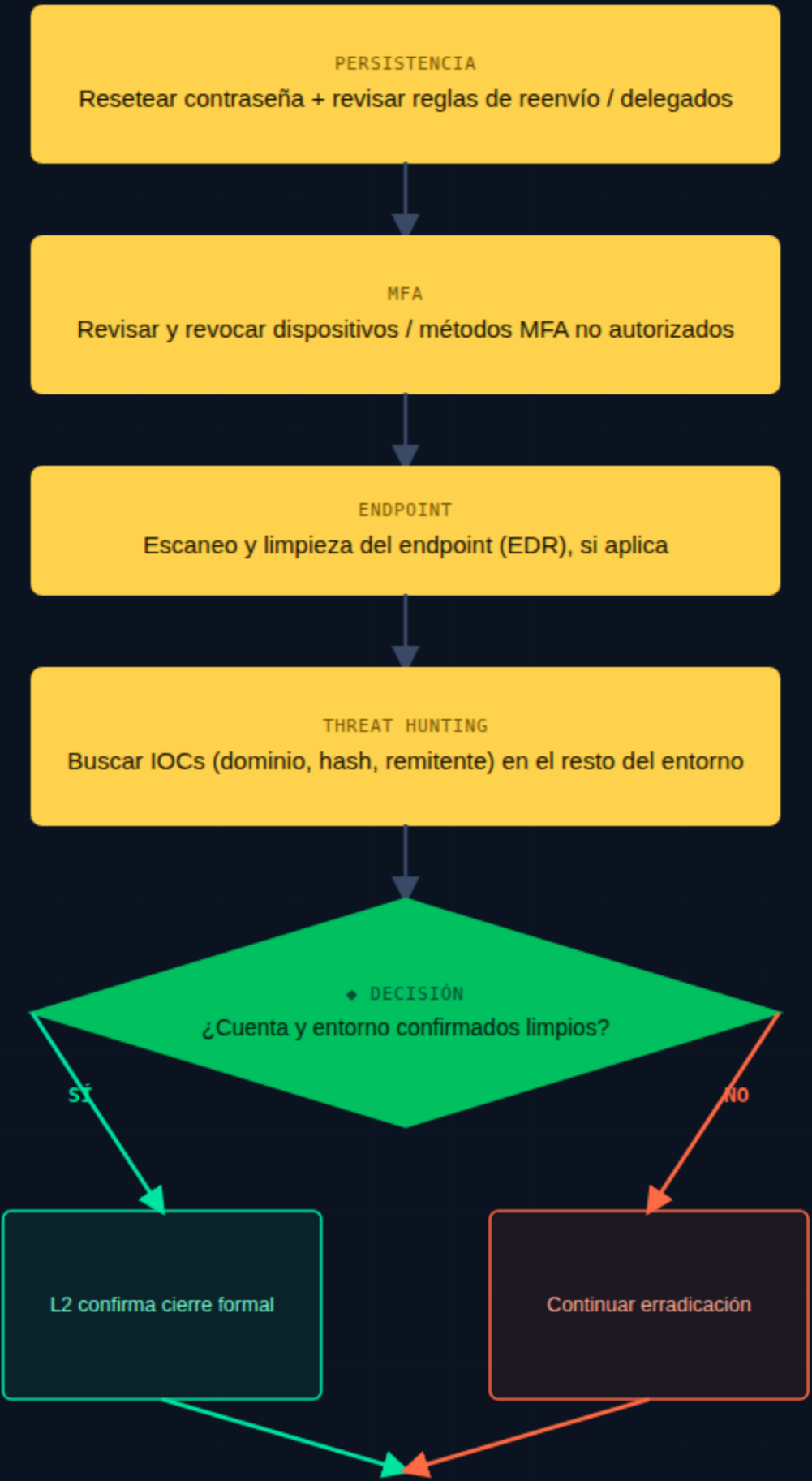


HERRAMIENTAS – CONTENCIÓN

- ▶ Microsoft Defender for Office 365
- ▶ Google Workspace Security Center
- ▶ Okta / Azure AD
- ▶ Fortinet FortiGate
- ▶ Palo Alto NGFW

Respuesta ante Phishing

FASE 3 – Erradicación

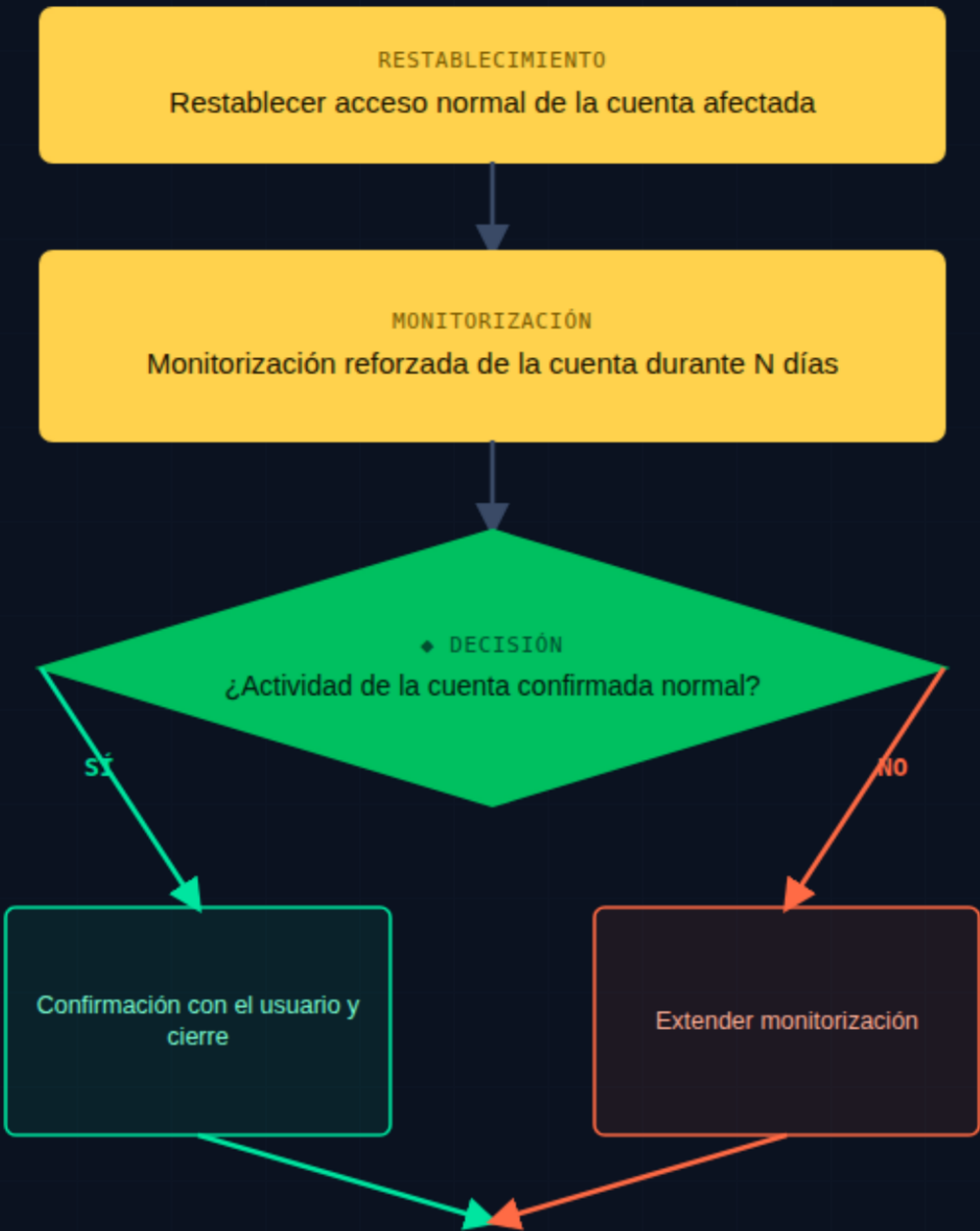


HERRAMIENTAS – ERRADICACIÓN

- CrowdStrike Falcon
- Microsoft Defender for Endpoint
- SentinelOne
- Okta / Azure AD (gestión MFA)

Respuesta ante Phishing

• FASE 4 – Recuperación



HERRAMIENTAS – RECUPERACIÓN

- Okta / Azure AD
- Splunk Enterprise Security
- Microsoft Sentinel
- Datadog

Respuesta ante Phishing

● FASE 5 – Lecciones Aprendidas



HERRAMIENTAS – LECCIONES APRENDIDAS

- ▶ TheHive
- ▶ ServiceNow ITSM
- ▶ Jira Service Management
- ▶ KnowBe4 (re-entrenamiento)

INFORME TÉCNICO DE DISEÑO Y COBERTURA

Playbook de Respuesta ante Incidentes de Phishing (SOC-IR-041)

Campo	Detalle
Documento de referencia	Playbook SOC-IR-041 — Versión 1.0 (documento independiente)
Tipo de documento	Informe técnico de diseño, metodología y cobertura
Clasificación	Confidencial / Uso Interno
Marcos de referencia	NIST SP 800-61 Rev. 2, MITRE ATT&CK, SANS Incident Handler's Handbook, ISO/IEC 27035
Fecha del informe	21 de junio de 2026
Elaborado por	Asistente de Ciberseguridad Defensiva (Blue Team)

Nota: a diferencia del playbook de ransomware (SOC-IR-042), que se construyó a partir de la revisión de un documento previo, este playbook de phishing (SOC-IR-041) se diseñó directamente bajo el estándar completo de nueve elementos. Por eso este informe documenta metodología y cobertura, no brechas corregidas. El procedimiento operativo completo se entrega como documento independiente: *Playbook de Respuesta ante Phishing — SOC-IR-041 v1.0*.

1. Resumen Ejecutivo

Este informe documenta el diseño del playbook SOC-IR-041, desarrollado para cubrir de forma completa el ciclo de vida de respuesta ante incidentes de phishing definido por NIST SP 800-61: Preparación, Detección y Análisis, Contención, Erradicación, Recuperación y Lecciones Aprendidas. El phishing es el vector de acceso inicial más frecuente en incidentes mayores (incluyendo ransomware y fraude financiero), por lo que el playbook distingue desde el triage inicial entre un correo reportado sin interacción y un caso con interacción confirmada del usuario, y contempla un camino de escalado específico para Business Email Compromise (BEC) dado su impacto financiero directo e inmediato.

El playbook resultante cubre los nueve elementos que un Procedimiento Operativo Estándar (POE) debe contener para ser ejecutable bajo presión: nombre y alcance, triggers de activación, roles y responsables, fases del proceso según el ciclo NIST, acciones técnicas concretas por fase, mapeo a MITRE ATT&CK, criterios de escalado, pautas de comunicación y métricas de cierre.

2. Alcance y Metodología de Diseño

El playbook SOC-IR-041 se desarrolló aplicando la misma checklist de nueve elementos utilizada en la revisión del playbook de ransomware (SOC-IR-042), derivada de los siguientes marcos de referencia:

- **NIST SP 800-61 Rev. 2** — ciclo de vida de gestión de incidentes: Preparación, Detección y Análisis, Contención/Erradicación/Recuperación, Actividad Post-Incidente.
- **MITRE ATT&CK** — taxonomía de tácticas y técnicas adversarias (TTPs), con énfasis en Initial Access (T1566) y las técnicas de persistencia y recolección que suelen seguir a un phishing exitoso.
- **SANS Incident Handler's Handbook** — estructura PICERL y buenas prácticas de documentación operativa.

- **ISO/IEC 27035** — gestión de incidentes de seguridad de la información, incluyendo roles, comunicación y mejora continua.

Los nueve elementos de diseño fueron: (1) nombre y alcance del playbook, (2) triggers de activación, (3) roles y responsables, (4) fases del proceso según el ciclo NIST, (5) acciones técnicas concretas por fase, (6) mapeo a MITRE ATT&CK, (7) criterios de escalado, (8) pautas de comunicación y (9) métricas de cierre.

3. Consideraciones de Diseño Específicas de Phishing

El phishing presenta particularidades frente a otros tipos de incidente que condicionaron decisiones de diseño concretas en el playbook:

- **Bifurcación temprana por interacción del usuario:** el diagrama de flujo separa desde el principio un correo solo reportado (de menor severidad, resuelto con purga y bloqueo) de uno con clic, adjunto ejecutado o credenciales ingresadas (que dispara contención de cuenta y endpoint). Tratar ambos casos igual habría generado fricción innecesaria en la mayoría de los reportes, que no implican compromiso real.
- **Verificación explícita de la purga:** se incorporó un punto de control específico ("¿purga confirmada en el 100% de los buzones?") con una vía manual de respaldo, porque las herramientas de purga automática (M365 Threat Explorer, Google Vault) no siempre alcanzan el 100% de los destinatarios en un primer intento, sobre todo con reglas de reenvío o buzones compartidos.
- **Camino de escalado dedicado a BEC:** a diferencia de un phishing genérico, el Business Email Compromise involucra una ventana de tiempo crítica para congelar transferencias financieras; por eso el playbook define una notificación directa e inmediata a Finanzas/Tesorería, fuera del flujo de ticketing habitual (sección 9).
- **Persistencia poco evidente:** se incorporó la revisión de reglas de reenvío automático y delegados de buzón en la fase de Erradicación, una técnica de persistencia (T1114.003) que un escaneo de endpoint estándar no detecta, ya que ocurre enteramente dentro del buzón de correo.
- **Comunicación sin tono punitivo:** el playbook indica explícitamente comunicarse con el usuario afectado de forma directa y no punitiva, dado que la disposición a reportar incidentes futuros depende de que el usuario no asocie el reporte con una sanción.

4. Cobertura frente a la Checklist de Nueve Elementos

La siguiente tabla confirma dónde se aborda cada uno de los nueve elementos dentro del Playbook SOC-IR-041, a modo de autoevaluación de completitud previa a la aprobación del CISO.

#	Elemento de la checklist	Sección en Playbook SOC-IR-041 v1.0
1	Nombre y alcance del playbook	Sección 2 — Alcance y Marco de Referencia
2	Triggers de activación	Sección 3 — Trigger / Criterios de Activación
3	Roles y responsables	Sección 4 — Roles y Responsables
4	Fases del proceso según el ciclo NIST	Sección 6 — Fases del Proceso (6.0 a 6.5)
5	Acciones técnicas concretas por fase	Sección 6, con detalle adicional en el diagrama de flujo
6	Mapeo a MITRE ATT&CK	Sección 7 — Mapeo a MITRE ATT&CK

#	Elemento de la checklist	Sección en Playbook SOC-IR-041 v1.0
7	Criterios de escalado	Sección 9 — Criterios de Escalado (incluye vía dedicada a BEC)
8	Pautas de comunicación	Sección 10 — Comunicación
9	Métricas de cierre	Sección 11 — Métricas de Cierre

El Playbook SOC-IR-041 incluye además el diagrama de flujo granular (con opciones de herramientas por fase), la tabla de herramientas y configuraciones críticas, y su propio control de versiones.

5. Recomendaciones y Próximos Pasos

1. Formalizar la sección de Roles y Responsables del Playbook con nombres/equipos reales, en particular el contacto directo de Finanzas/Tesorería para el camino de escalado por BEC.
2. Probar mediante un simulacro (tabletop exercise) el escenario de Business Email Compromise, dado que es el de mayor impacto financiero potencial y el menos frecuente en la práctica.
3. Validar con Legal/DPO los criterios exactos para determinar cuándo un buzón comprometido implica datos personales sujetos a notificación regulatoria.
4. Integrar la plataforma de triage de reportes de usuarios (p. ej. Cofense Triage) con el SIEM para automatizar la búsqueda retrospectiva de destinatarios (sección 6.1).
5. Revisar y actualizar este playbook con periodicidad semestral o tras cualquier campaña masiva o caso de BEC exitoso.
6. Aplicar esta misma checklist de nueve elementos al resto de playbooks del catálogo del SOC para mantener consistencia documental.

6. Historial del Informe

Versión	Fecha	Cambios	Autor
1.0	21 jun. 2026	Versión inicial: metodología de diseño, consideraciones específicas de phishing y verificación de cobertura frente a la checklist de nueve elementos	Asistente de Ciberseguridad Defensiva

CONFIDENCIAL — USO INTERNO

PLAYBOOK DE RESPUESTA ANTE INCIDENTES

Procedimiento Operativo Estándar frente a Phishing

SOC-IR-041 · Versión 1.0

Código	SOC-IR-041
Versión	1.0
Clasificación	Confidencial / Uso Interno
Estado	Vigente
Marcos de referencia	NIST SP 800-61 Rev. 2 · MITRE ATT&CK · SANS · ISO/IEC 27035
Última revisión	21 de junio de 2026
Autor	Equipo de Ingeniería del SOC
Aprobado por	CISO

1. Resumen Ejecutivo

Este playbook establece el procedimiento operativo estándar para detectar, contener, erradicar y recuperar la infraestructura corporativa frente a incidentes de phishing, así como para coordinar la comunicación interna, regulatoria y externa asociada. Cubre el ciclo completo de gestión de incidentes conforme a NIST SP 800-61 Rev. 2 (Preparación, Detección y Análisis, Contención, Erradicación, Recuperación y Actividad Post-Incidente).

El diseño distingue desde el triage inicial dos escenarios con ramificaciones completamente distintas: el correo reportado sin interacción del usuario (riesgo bajo, purga y bloqueo) y el caso con clic, adjunto ejecutado o credenciales ingresadas (riesgo alto, la cuenta se trata como comprometida). Tratarlos con el mismo procedimiento genera demasiada fricción en el caso fácil o demasiado poco rigor en el caso grave. Se incluye además un camino de escalado dedicado para Business Email Compromise (BEC), dado su impacto financiero directo con ventana de acción de minutos.

2. Alcance y Marco de Referencia

Nombre: Respuesta ante Incidentes de Phishing

Código: SOC-IR-041 · Versión 1.0

Cubre: correos de phishing genérico, spear-phishing, smishing con derivación a correo corporativo, y Business Email Compromise (BEC). Incluye casos con y sin interacción confirmada del usuario.

No cubre: malware descargado que evoluciona a ransomware (ver SOC-IR-042), ataques DDoS (ver SOC-IR-043), ni accesos no autorizados sin vector de correo electrónico confirmado.

Marcos de referencia:

- NIST SP 800-61 Rev. 2 — ciclo de vida de gestión de incidentes.
- MITRE ATT&CK — Initial Access (T1566), Persistence (T1114.003), Credential Access (T1078).
- SANS Incident Handler's Handbook — estructura PICERL y buenas prácticas operativas.
- ISO/IEC 27035 — gestión de incidentes, roles, comunicación y mejora continua.

3. Trigger / Criterios de Activación

Este playbook se activa formalmente ante cualquiera de los siguientes eventos:

- Reporte de un usuario sobre un correo sospechoso recibido (con o sin interacción).
- Alerta del SEG (Secure Email Gateway) sobre un mensaje que superó los filtros y llegó al buzón del usuario.
- Alerta del SIEM por correlación de eventos: correo entregado + navegación a dominio categorizado como malicioso + ejecución de proceso sospechoso en el endpoint del receptor.
- Alerta del EDR sobre proceso sospechoso iniciado desde cliente de correo o lector de PDF.
- Detección de regla de reenvío automático creada en un buzón corporativo sin autorización (T1114.003).

- Notificación de un proveedor, cliente o CSIRT externo sobre campaña de phishing que suplanta la identidad de la organización.
- Solicitud de transferencia bancaria inusual recibida desde una cuenta aparentemente interna (indicador de BEC).

4. Roles y Responsables

Rol	Responsabilidad en el playbook	Fase principal
Analista SOC L1	Triage inicial: clasifica el correo, determina si hubo interacción, escala al L2	Detección y Análisis
Analista SOC L2	Investiga IOCs, ejecuta contención de cuenta y endpoint si aplica, coordina purga	Detección / Contención
Analista SOC L3 / Threat Hunter	Análisis forense del endpoint y buzón; threat hunting con IOCs confirmados	Erradicación
IR Lead	Activa formalmente el playbook, coordina fases, autoriza acciones de alto impacto y escalado BEC	Todas
Administrador de correo / IT	Ejecuta purga manual buzón por buzón si la herramienta automática no alcanza el 100%	Contención
Equipo IAM	Revoca sesiones, tokens y dispositivos MFA no autorizados de cuentas comprometidas	Contención / Erradicación
Finanzas / Tesorería	Pausa transferencias pendientes ante alerta BEC (notificación directa, fuera del ticketing)	Escalado BEC
Legal / DPO	Evalúa obligaciones de notificación regulatoria si hay datos personales comprometidos	Comunicación
CISO / Dirección	Aprueba decisiones críticas en casos de BEC con impacto financiero mayor	Escalado mayor

5. Diagrama de Flujo General

El procedimiento sigue la lógica granular del diagrama oficial SOC-IR-041: cada nodo representa una acción o decisión individual. La bifurcación principal ocurre en el rombo '¿El usuario hace clic, abre el adjunto o ingresa credenciales?' — a partir de ahí los dos caminos son completamente distintos en urgencia, herramientas y escalado.



Documento independiente: el diagrama completo en alta resolución se entrega como archivo separado — Diagrama_Flujo_Phishing_SOC-IR-041 — en formato PDF (póster vectorial), Word y SVG editable. Notación: círculo = inicio/fin · rectángulo = acción · rombo = decisión · recuadro rojo = vía manual de contingencia.

6. Fases del Proceso (Ciclo NIST SP 800-61)

6.0 Preparación

La preparación es la única fase que ocurre antes del incidente y la que más impacto tiene en la velocidad de respuesta:

- Configurar y mantener el SEG (Defender for Office 365, Proofpoint TAP o Mimecast) con políticas de cuarentena, sandboxing de adjuntos y autenticación SPF/DKIM/DMARC activas.
- Habilitar la integración del SEG con el SIEM para ingesta automática de logs de correo y búsqueda retrospectiva de destinatarios.
- Ejecutar simulacros de phishing periódicos (KnowBe4, Microsoft Attack Simulation Training) para medir la tasa de clic y dirigir la formación a los usuarios con mayor riesgo.
- Documentar el procedimiento de contacto de urgencia con Finanzas/Tesorería (nombre y teléfono directo) para el camino de escalado BEC — debe estar disponible sin depender de sistemas que puedan estar comprometidos.
- Validar este playbook mediante tabletop exercises al menos semestralmente, incluyendo el escenario BEC.

6.1 Detección y Análisis

El objetivo de esta fase es confirmar que el correo es malicioso (no un falso positivo) y clasificar el nivel de riesgo antes de ejecutar cualquier acción de contención.

- **Triage L1 — cabeceras y autenticación:** verificar SPF, DKIM y DMARC del remitente. Un fallo de autenticación junto con contenido de ingeniería social es indicador de alta confianza.
- **Extracción de IOCs:** cabeceras completas del correo, URLs (expandidas si están acortadas), hashes de adjuntos, dominio del remitente y dirección IP de origen.
- **Análisis de reputación:** VirusTotal (hash y URL), Urlscan.io (captura del sitio en el momento del análisis), sandbox inline del SEG o externo (Any.run, Joe Sandbox).
- **Búsqueda retrospectiva:** identificar todos los buzones que recibieron el mismo correo o variantes de la misma campaña (mismo remitente, mismo adjunto, mismo dominio de enlace).
- **Clasificación de severidad:** masiva (misma organización, múltiples destinatarios), dirigida (spear-phishing a un directivo o rol específico) o BEC (solicitud de transferencia o cambio de datos bancarios).
- **Verificación de interacción:** EDR y proxy confirman si el usuario navegó al dominio malicioso o ejecutó el adjunto. Esta verificación determina la bifurcación del procedimiento.



BIFURCACIÓN CRÍTICA: Si el EDR o el proxy NO confirman interacción → seguir el camino A (bajo riesgo). Si confirman clic, ejecución o ingreso de credenciales → seguir el camino B (alto riesgo). Ambos caminos se describen en las secciones 6.2 y 6.3.

6.2 Contención

Camino A — Sin interacción del usuario (bajo riesgo)

Urgencia: media. Tiempo objetivo: resolución en menos de 4 horas.

1. Purgar el correo malicioso de todos los buzones que lo recibieron usando ZAP (Zero-hour Auto Purge) de Microsoft 365 o la función equivalente de Google Vault / Proofpoint.
2. **Punto de control obligatorio:** ¿la purga alcanzó el 100% de los buzones identificados?
3. **Si NO al 100%:** ejecutar eliminación manual buzón por buzón coordinando con IT/Helpdesk. Documentar los buzones que requirieron intervención manual.
4. Bloquear el remitente, el dominio y la IP de origen en el SEG y en el firewall perimetral.
5. Notificar al usuario afectado de forma directa y no punitiva (ver sección 10).
6. Si la campaña es masiva: notificar al equipo de concienciación para refuerzo formativo dirigido.

Camino B — Con interacción confirmada (alto riesgo)

Urgencia: alta. Tiempo objetivo: acciones de contención de cuenta en menos de 15 minutos.

7. Deshabilitar la cuenta del usuario afectado en el directorio activo / IAM.
8. Revocar todas las sesiones activas y tokens de acceso (Okta, Microsoft Entra ID / Azure AD).
9. **Punto de control — ¿hubo ingreso de credenciales o malware confirmado?**
10. **Si hubo ingreso de credenciales:** aislar el endpoint afectado vía EDR, preservar evidencia forense antes de cualquier remediación, abrir ticket crítico con IR Lead.
11. **Si solo hubo clic en URL (sin ejecución confirmada):** monitorización preventiva reforzada de la cuenta, sin aislamiento inmediato del endpoint pero con escalado al L2.
12. Ejecutar la purga del correo original y bloqueos de remitente/dominio/IP (igual que Camino A).

Escalado BEC — Business Email Compromise

! ACCIÓN INMEDIATA: Si el triage identifica un posible BEC (solicitud de transferencia o cambio de datos bancarios desde una cuenta aparentemente legítima), notificar DIRECTAMENTE por teléfono al responsable de Finanzas/Tesorería ANTES de continuar con el procedimiento estándar. La ventana para detener una transferencia puede ser de minutos. Este paso no espera al IR Lead ni al ticket.

- Tras la notificación a Tesorería: activar el procedimiento de Camino B con prioridad máxima.
- Coordinar con el banco para intentar detener o revertir la transferencia si ya se ha ejecutado.
- Escalar de inmediato al IR Lead y al CISO.

6.3 Erradicación

El objetivo es eliminar cualquier persistencia que el atacante haya establecido en el buzón o en el endpoint. Esta fase aplica principalmente al Camino B.

- **Reglas de reenvío y delegados:** revisar y eliminar cualquier regla de reenvío automático (T1114.003) o delegado de buzón creado sin autorización. Esta técnica de persistencia no es detectada por un escaneo de endpoint estándar porque ocurre íntegramente dentro del servidor de correo.

- **Dispositivos y métodos MFA:** revisar y revocar dispositivos de autenticación multifactor no reconocidos registrados en la cuenta comprometida.
- **Escaneo y limpieza del endpoint:** si se confirmó ejecución de malware, ejecutar escaneo completo con el EDR y eliminar todos los artefactos identificados.
- **Threat hunting con IOCs:** buscar el dominio malicioso, el hash del adjunto y la dirección del remitente en los logs del resto del entorno para identificar afectación adicional no detectada en el triage inicial.
- **Confirmación de limpieza:** el Analista L2 confirma formalmente el cierre de la fase de erradicación antes de autorizar la recuperación de acceso.

6.4 Recuperación

- Restablecer el acceso normal de la cuenta afectada una vez confirmada la limpieza del buzón y del endpoint.
- Forzar el restablecimiento de contraseña por parte del usuario.
- Mantener monitorización reforzada de la cuenta durante un período definido (mínimo N días según criticidad del rol).
- Solicitar confirmación del usuario de que el acceso es normal y que no detecta actividad no reconocida.
- Si el incidente implicó datos personales de terceros: coordinar con Legal/DPO la evaluación de obligaciones de notificación regulatoria (ver sección 10).

6.5 Lecciones Aprendidas

- Convocar post-mortem dentro de los 5-10 días hábiles siguientes al cierre, con todos los roles de la sección 4 involucrados en el incidente.
- Actualizar las reglas del SEG con los nuevos IOCs (dominio, remitente, hash de adjunto).
- Si fue una campaña masiva o un caso de BEC exitoso: ejecutar un simulacro dirigido específicamente al perfil de usuario afectado.
- Evaluar si corresponde compartir los IOCs con el CSIRT nacional o con el sector bajo el protocolo TLP adecuado.
- Actualizar este playbook con los hallazgos obtenidos antes del cierre formal del expediente.

7. Mapeo a MITRE ATT&CK

Fase	Táctica (ID)	Técnica (ID)	Evidencia / detección
Detección	Initial Access (TA0001)	T1566 Phishing	Vector de entrada: correo malicioso con enlace o adjunto weaponizado
Detección	Initial Access (TA0001)	T1566.001 Spearphishing Attachment	Adjunto ejecutable o documento con macro maliciosa
Detección	Initial Access (TA0001)	T1566.002 Spearphishing Link	URL maliciosa en el cuerpo del correo

Fase	Táctica (ID)	Técnica (ID)	Evidencia / detección
Contención	Credential Access (TA0006)	T1078 Valid Accounts	Uso de credenciales comprometidas; revocación de sesiones en IAM
Erradicación	Persistence (TA0003)	T1114.003 Email Forwarding Rule	Regla de reenvío creada por el atacante en el buzón comprometido
Erradicación	Execution (TA0002)	T1059.001 PowerShell	Comandos codificados detectados si el adjunto ejecutó un dropper
Recuperación	Defense Evasion (TA0005)	T1036 Masquerading	Correo BEC que suplanta identidad legítima de remitente interno

8. Herramientas y Configuraciones Críticas

Componente	Herramientas de referencia	Configuraciones críticas
Gateway de correo / SEG	Proofpoint TAP, Mimecast, Microsoft Defender for Office 365	Activar sandboxing de adjuntos, SPF/DKIM/DMARC en modo reject, ZAP habilitado, integración con SIEM para ingesta de logs de correo.
SIEM	Splunk Enterprise Security, Microsoft Sentinel, Wazuh	Reglas de correlación: correo entregado + navegación a dominio sospechoso + proceso hijo de cliente de correo. Ingesta de logs de proxy y EDR.
EDR	CrowdStrike Falcon, SentinelOne, Microsoft Defender for Endpoint	Modo Enforce/Protection activo. Alertas sobre procesos hijos de Outlook/Thunderbird. Capacidad de aislamiento de host vía API.
IAM	Okta, Microsoft Entra ID (Azure AD), Google Workspace	Revocación de sesiones y tokens por API. Revisión de dispositivos MFA registrados. MFA obligatorio para todos los usuarios.
Análisis de IOCs	VirusTotal Enterprise, Urlscan.io, Any.run, Joe Sandbox	API de VirusTotal para enriquecimiento automático de hashes y URLs. Urlscan para captura del sitio en el momento del análisis.
Plataforma de triage	Cofense Triage, Microsoft Attack Simulator	Integración con SIEM para automatizar búsqueda retrospectiva de destinatarios al recibir un reporte de usuario.
Gestión de incidentes	TheHive, ServiceNow ITSM, Jira Service Management	Plantilla de caso phishing con campos: tipo (genérico/spear/BEC), IOCs, destinatarios afectados, estado de purga.

9. Criterios de Escalado

Transición	Condición de escalado	Destinatario	Tiempo máximo
L1 → L2	Interacción del usuario confirmada (clic, ejecución o credenciales)	Analista SOC L2	15 minutos
L1 → Finanzas (BEC)	Solicitud de transferencia bancaria o cambio de datos de pago desde cuenta aparentemente interna	Responsable de Tesorería (llamada directa)	INMEDIATO
L2 → IR Lead	Malware confirmado en endpoint, más de 5 cuentas afectadas, o campaña BEC activa	IR Lead	30 minutos
L2 → L3	Ejecución de malware confirmada que requiere análisis forense del endpoint	Analista L3 / Threat Hunter	30 minutos
IR Lead → CISO	BEC con transferencia ejecutada, spear-phishing a directivos, o indicios de compromiso de cuenta privilegiada	CISO, Dirección	1 hora
IR Lead → Legal/DPO	Posible exposición de datos personales de clientes, empleados o terceros	Legal / DPO	1-2 horas

10. Comunicación

- **Con el usuario afectado:** comunicación directa, clara y no punitiva. El usuario que reportó el correo actuó correctamente. La disposición a reportar incidentes futuros depende de que el usuario no asocie este reporte con una sanción o juicio negativo.
- **Notificación interna al equipo:** incluir hora de detección, tipo de incidente (genérico / spear / BEC), estado de la contención y próximos pasos. Evitar información especulativa sobre alcance o causa raíz hasta su confirmación.
- **Escalado BEC a Finanzas:** llamada telefónica directa al responsable de Tesorería. Mensaje concreto: 'Hay un posible BEC activo. Pausa cualquier transferencia pendiente de [cuenta/beneficiario] hasta nueva confirmación de nuestra parte.' No esperar al ticket ni al correo electrónico.
- **Notificación regulatoria:** Legal/DPO determina si el buzón comprometido implica datos personales sujetos a notificación (RGPD: máximo 72 horas desde el conocimiento del incidente). El IR Lead provee la información técnica necesaria dentro del plazo definido en la sección 9.
- **Comunicación externa:** si la campaña suplanta la identidad de la organización o si clientes han sido afectados, la comunicación externa se gestiona exclusivamente por Comunicación/PR bajo aprobación de Dirección.

11. Métricas de Cierre

Indicadores clave de rendimiento a registrar en cada incidente:

- **MTTD (Mean Time to Detect):** tiempo desde la entrega del correo malicioso hasta la generación de la alerta o el reporte del usuario.
- **MTTC (Mean Time to Contain):** tiempo desde la alerta hasta la purga confirmada del correo en el 100% de los buzones y el bloqueo del remitente/dominio.
- **MTTR (Mean Time to Recover):** tiempo desde el inicio de la contención hasta la restauración del acceso normal de todas las cuentas afectadas.

Evidencia mínima a documentar para el cierre del incidente:

- Cronograma completo (timestamps de cada fase y acción ejecutada).
- IOCs confirmados: remitente, dominio, IP, hash del adjunto, URL del enlace.
- Lista de buzones afectados y estado de purga (automática / manual).
- Cuentas con interacción confirmada y acciones de contención aplicadas.
- Resultado de la verificación de reglas de reenvío y dispositivos MFA.
- Hallazgos de la reunión de lecciones aprendidas y cambios aplicados al playbook.

12. Revisión y Mantenimiento

13. Este playbook se revisa con periodicidad semestral, o de forma inmediata tras cualquier campaña masiva o caso de BEC exitoso.
14. Toda modificación debe quedar registrada en el control de versiones (sección 13) y ser aprobada por el CISO.
15. Los roles y contactos de la sección 4 (especialmente el contacto de Tesorería para BEC) deben validarse trimestralmente.
16. Los plazos de notificación regulatoria deben confirmarse con Legal/DPO ante cambios normativos.

13. Control de Versiones

Versión	Fecha	Cambios	Autor
1.0	21 jun. 2026	Versión inicial: ciclo NIST íntegro, bifurcación A/B, escalado BEC, punto de control de purga, mapeo MITRE, métricas y diagrama de flujo granular	Equipo de Ingeniería del SOC